

API TESTING MASTERCLASS

API Testing Checklist

A thorough checklist to cover before you sign off an API.

How to Use This Checklist

Work through each section for the endpoints you own. Tick an item only when you have genuinely observed the behaviour — not when you assume it. Not every line applies to every endpoint; use judgement, but be able to justify anything you skip.

Functional / CRUD

- Verified that a valid POST creates the resource and returns it (or its location).
- Verified that GET returns the resource just created, with the values sent.
- Verified that PUT/PATCH updates the resource and the change persists on a subsequent GET.
- Verified that DELETE removes the resource and a following GET returns 404.
- Verified that list/collection endpoints return the expected items with working pagination, filtering and sorting.

Status Codes

- Verified that success responses use the correct 2xx code (200 read/update, 201 create, 204 no content).
- Verified that bad input returns 400 and not a 500.
- Verified that missing/invalid auth returns 401 and forbidden access returns 403.
- Verified that unknown resources return 404.
- Verified that the wrong HTTP method on a valid path returns 405.
- Verified that server faults return 5xx and are not masked as 200.

Response Body & Schema

- Verified that the response matches the agreed schema (field names, types and structure).
- Verified that required fields are always present and correctly typed.
- Verified that optional/null fields behave as documented rather than breaking clients.
- Verified that no sensitive fields (password hashes, internal IDs, tokens) leak in the payload.
- Verified that dates, numbers and enums use consistent formats across endpoints.

Negative & Error Handling

- Verified that missing required fields return a clear, structured error.
- Verified that wrong data types and malformed JSON are rejected gracefully (no stack trace to the client).
- Verified that error responses use a consistent shape (code, message, details).
- Verified that error messages are helpful to developers without exposing internal implementation detail.

Boundary & Edge Cases

- Verified minimum and maximum values for numeric and length-limited fields, plus just-over-the-limit values.
- Verified empty strings, empty arrays and empty request bodies where relevant.
- Verified very large payloads and long strings are handled or rejected cleanly.
- Verified special characters, Unicode and injection-style input are handled safely.
- Verified duplicate creation and idempotency behave as documented.

Headers & Content Types

- Verified that Content-Type on requests and responses is correct (e.g. application/json).
- Verified that the API rejects or handles an unsupported Accept / Content-Type appropriately (e.g. 415).
- Verified that required custom and correlation headers are honoured.
- Verified that CORS and caching headers are set as expected for the client.

Authentication & Authorisation

- Verified that protected endpoints reject requests with no token (401).
- Verified that expired, malformed or tampered tokens are rejected.
- Verified that a user cannot access or modify another user's data (no broken object-level authorisation).
- Verified that role/permission boundaries are enforced (403 for insufficient rights).
- Verified that tokens and credentials are never returned or logged in responses.

Performance Basics

- Verified that typical requests respond within an acceptable, agreed time.
- Verified that list endpoints paginate rather than returning unbounded result sets.
- Verified behaviour under a modest concurrent load (no obvious errors or timeouts).
- Verified that rate limiting (if any) responds with 429 and is documented.

Contract / Versioning

- Verified that the response conforms to the published contract / OpenAPI spec.
- Verified that the API version is clear (URL or header) and behaves as documented.
- Verified that changes are backwards compatible, or the version was bumped.
- Verified that adding a new optional field does not break existing consumers.

Documentation & Handover

- Verified that every endpoint, parameter and status code is documented and matches actual behaviour.
- Verified that example requests and responses are present and correct.

- Verified that authentication and error formats are explained.
- Verified that the Postman collection / Newman run is exported, committed and reproducible by someone else.
- Verified that known limitations and open issues are recorded for handover.

INSIDE STLC PRO TIP

A tick means "I saw this happen", not "this should work". The most valuable rows on this checklist are the negative, authorisation and boundary cases — those are exactly where APIs fail in production, and exactly where testers who only check the happy path miss the real defects.